

Marco integrativo GQM + PRAGMATIC para indicadores SSVC a nivel nacional

Este documento define, para cada indicador propuesto en el informe SSVC a escala nacional/territorial, su articulación mediante la metodología GQM (Goal–Question–Metric) y su evaluación cualitativa según los criterios PRAGMATIC. [web:19][web:24][web:6][web:22][web:25][web:33]

1. Referencia rápida: indicadores SSVC a nivel nacional

Tomamos como base los indicadores agrupados en tres capas:

1. Indicadores de datos (disponibilidad y calidad de información SSVC).
2. Indicadores de decisión (cómo se aplica SSVC a nivel de país/sector).
3. Indicadores de eficacia y resiliencia (resultados reales). [web:6][web:19][web:25][web:27][web:32][web:33]

2. Capa de datos: objetivos, preguntas y métricas

2.1. GQM – Cobertura de evaluaciones SSVC sobre CVE relevantes

Goal (G1)

Mejorar la capacidad nacional de priorizar vulnerabilidades basándose en información SSVC completa y actualizada para los CVE relevantes para el parque tecnológico nacional. [web:19][web:22][web:25][web:28]

Questions

Q1.1. ¿Qué porcentaje de CVE relevantes para el país disponen de puntos de decisión SSVC básicos (explotación, impacto técnico, automatización)? [web:19][web:22][web:24]

Q1.2. ¿Qué porcentaje de CVE relevantes han sido revisados/ajustados por el CERT nacional para reflejar el contexto local? [web:6][web:7][web:10]

Metrics

M1.1. Porcentaje de CVE relevantes con evaluación SSVC básica disponible

- Definición:

($M1.1 = \frac{\text{Nº de CVE relevantes con todos los campos SSVC básicos poblados}}{\text{Nº total de CVE relevantes}} \times 100$)

- Fuente: repositorios CVE enriquecidos (Vulnrichment, KEV, CSAF), inventario nacional/CPE. [web:19][web:22][web:25][web:28]

M1.2. Porcentaje de CVE relevantes con evaluación SSVC revisada localmente

- Definición:

($M1.2 = \frac{\text{Nº de CVE relevantes con SSVC ajustado por CERT nacional}}{\text{Nº total de CVE relevantes}} \times 100$)

- Fuente: base de datos del CERT nacional (INCIBE-CERT, CCN-CERT) con campo de “override” local. [web:7][web:10][web:19]

2.2. GQM – Cobertura de inventario y correlación con SSVC

Goal (G2)

Asegurar que los activos críticos nacionales puedan mapearse de forma automática a vulnerabilidades con evaluación SSVC, para permitir priorización masiva. [web:19][web:24][web:33]

Questions

Q2.1. ¿Qué porcentaje de activos críticos nacionales están inventariados con identificadores CPE/SBOM adecuados? [web:33]

Q2.2. ¿Qué porcentaje de esos activos está vinculado a CVE con evaluación SSVC? [web:19][web:22]

Metrics

M2.1. Porcentaje de activos críticos con identificadores normalizados

- Definición: activos críticos con CPE/SBOM válido / activos críticos totales.

- Fuente: inventario nacional/sectorial de activos críticos, requisitos NIS/NIS2. [web:33][web:39]

M2.2. Porcentaje de activos críticos cubiertos por CVE con SSVC

- Definición:

($M2.2 = \frac{\text{Nº de activos críticos que tienen al menos un CVE con SSVC asociado}}{\text{Nº total de activos críticos}} \times 100$)

- Fuente: correlación inventario–CPE–CVE–SSVC. [web:19][web:22][web:25]

2.3. GQM – Tiempo de disponibilidad de evaluación SSVC

Goal (G3)

Reducir el tiempo desde la publicación del CVE hasta la disponibilidad de una evaluación SSVC utilizable por los operadores nacionales. [web:19][web:22][web:25]

Questions

Q3.1. ¿Cuál es el tiempo medio entre la publicación del CVE y la publicación de evaluación SSVC básica (global)?

Q3.2. ¿Cuál es el tiempo medio hasta el ajuste local por parte del CERT nacional? [web:6][web:19]

Metrics

M3.1. Tiempo medio global de enriquecimiento SSVC

- Definición: media de días entre fecha CVE y fecha de SSVC global disponible para CVE relevantes.

M3.2. Tiempo medio de ajuste SSVC local

- Definición: media de días entre fecha de SSVC global y fecha de publicación de decisión SSVC adaptada al contexto nacional.

3. Capa de decisión: objetivos, preguntas y métricas

3.1. GQM - Volumen y distribución de decisiones Act/Attend/Track

Goal (G4)

Garantizar que la priorización nacional distingue claramente entre vulnerabilidades que requieren acción inmediata, acción programada y seguimiento, permitiendo una gestión racional de recursos. [web:24][web:6][web:25]

Questions

Q4.1. ¿Qué proporción de vulnerabilidades que afectan a activos críticos nacionales se clasifican como Act, Attend y Track? [web:6][web:24]

Q4.2. ¿Cómo varía esta distribución por sector (energía, salud, administración, etc.)? [web:33]

Metrics

M4.1. Proporción de decisiones Act, Attend, Track sobre CVE que afectan a activos críticos

- Definición: distribución porcentual de acciones SSVC sobre el conjunto de CVE relevantes para activos críticos. [web:24][web:6]

M4.2. Proporción Act/Attend/Track por sector

- Definición: mismo cálculo que M4.1, desagregado por sector NIS2. [web:33][web:39]

3.2. GQM - Tiempo de respuesta desde decisión a remediación

Goal (G5)

Reducir el tiempo desde la emisión de una decisión SSVC nacional (especialmente Act) hasta la remediación efectiva en los operadores de servicios esenciales. [web:6][web:33][web:32]

Questions

Q5.1. ¿Cuál es el tiempo medio de remediación para vulnerabilidades con decisión Act?

Q5.2. ¿Qué porcentaje de vulnerabilidades Act se remedia dentro de los plazos nacionales definidos (SLA)? [web:33][web:39]

Metrics

M5.1. MTTR nacional para vulnerabilidades Act

- Definición: media de días entre publicación de decisión Act y fecha de remediación confirmada por el operador (por sector). [web:32][web:27]

M5.2. Porcentaje de vulnerabilidades Act remediadas en plazo

- Definición:

$$(M5.2 = \frac{\text{Nº de vulnerabilidades Act remediadas} \leq \text{SLA}}{\text{Nº total de vulnerabilidades Act}} \times 100)$$

- Fuente: reporting de operadores, CERT nacional, regulador NIS2. [web:33][web:36][web:32]

3.3. GQM – Coherencia entre decisiones nacionales y locales

Goal (G6)

Asegurar la coherencia y justificación de decisiones de priorización entre recomendaciones nacionales y decisiones de los operadores, evitando tanto relajaciones injustificadas como sobrereacciones. [web:24][web:33][web:39]

Questions

Q6.1. ¿Con qué frecuencia los operadores modifican la categoría SSVC recomendada (por ejemplo, rebajan de Act a Attend)?

Q6.2. ¿Se documentan razonablemente las desviaciones? [web:33]

Metrics

M6.1. Tasa de discrepancias entre SSVC nacional y local

- Definición:

($M6.1 = \frac{\text{Nº de vulnerabilidades donde la acción local difiere de la nacional}}{\text{Nº total de vulnerabilidades con recomendación nacional}} \times 100$)

M6.2. Porcentaje de discrepancias con justificación documentada

- Definición: vulnerabilidades con discrepancia + justificación formal / total de discrepancias.

4. Capa de eficacia y resiliencia: objetivos, preguntas y métricas

4.1. GQM – Incidentes originados en vulnerabilidades mal priorizadas

Goal (G7)

Reducir el número de incidentes graves originados en vulnerabilidades cuya priorización no reflejaba adecuadamente su riesgo (falsos negativos del modelo SSVC). [web:16][web:20][web:25][web:27]

Questions

Q7.1. ¿Qué proporción de incidentes graves se debe a vulnerabilidades clasificadas como Track o Attend pero explotadas con impacto significativo? [web:16][web:20]

Q7.2. ¿Cómo evoluciona esta proporción en el tiempo tras ajustes del modelo? [web:27][web:32]

Metrics

M7.1. Porcentaje de incidentes graves debidos a vulnerabilidades no clasificadas como Act

- Definición:

($M7.1 = \frac{\text{Nº de incidentes graves originados en Track/Attend}}{\text{Nº total de incidentes graves por vulnerabilidades}} \times 100$)

M7.2. Tendencia interanual de M7.1

- Definición: variación anual (en puntos porcentuales) de M7.1.

4.2. GQM – Exposición acumulada a vulnerabilidades KEV

Goal (G8)

Minimizar el tiempo y volumen de exposición de infraestructuras críticas nacionales a vulnerabilidades incluidas en KEV y clasificadas como Act. [web:6][web:12][web:25]

Questions

Q8.1. ¿Cuál es la “superficie temporal” de exposición (días × activos) a vulnerabilidades KEV con decisión Act pendientes de remediación? [web:25]

Q8.2. ¿Cómo varía por sector y tipo de activo?

Metrics

M8.1. Tiempo acumulado de exposición a KEV-Act

- Definición conceptual: suma, para cada combinación activo–vulnerabilidad KEV con decisión Act, de los días desde la decisión hasta la remediación.
- Unidad: días-activo.

M8.2. Exposición media por operador/sector

- Definición: M8.1 dividido por número de activos críticos del sector o del operador.

4.3. GQM – Mejora interanual de priorización (efecto SSVc)

Goal (G9)

Demostrar que la adopción de SSVc y datos enriquecidos reduce backlog crítico y mejora la puntualidad de remediación sin comprometer la continuidad de servicios esenciales. [web:27][web:32][web:19][web:22][web:25]

Questions

Q9.1. ¿Cómo evoluciona el número de vulnerabilidades críticas abiertas (backlog) en los operadores a lo largo del tiempo? [web:27][web:32]

Q9.2. ¿Cómo cambian los tiempos de remediación de Act antes y después de la implantación de SSVc? [web:19]

Metrics

M9.1. Reducción interanual del backlog crítico

- Definición:

($M9.1 = \frac{\text{Backlog crítico año } N - \text{Backlog crítico año } N-1}{\text{Backlog crítico año } N-1} \times 100$) (valor negativo = mejora).

M9.2. Reducción del MTTR para Act tras SSVc

- Definición: diferencia (en días) entre MTTR promedio antes y después de adopción SSVc.

5. Síntesis: mapa GQM de alto nivel

En resumen, el marco GQM se articula así:

- **Objetivos estratégicos nacionales:**
 - G1–G3: asegurar datos SSVC suficientes y oportunos.
 - G4–G6: garantizar decisiones coherentes y plazos razonables.
 - G7–G9: demostrar que todo esto reduce incidentes y exposición.
- **Preguntas:** articulan las preocupaciones del regulador, del CERT nacional y de los operadores en términos de cobertura, tiempos, coherencia y resultados.
- **Métricas:** conectan, de forma cuantificable, los datos técnicos (CVE, SSVC, KEV, incidentes, SLA) con los objetivos de seguridad nacional y cumplimiento NIS2. [web:6][web:19][web:22][web:25][web:33][web:39]

Objetivos estratégicos nacionales:

- G1–G3: asegurar datos SSVC suficientes y oportunos.
- G4–G6: garantizar decisiones coherentes y plazos razonables.
- G7–G9: demostrar que todo esto reduce incidentes y exposición.

Preguntas: articulan las preocupaciones del regulador, del CERT nacional y de los operadores en términos de cobertura, tiempos, coherencia y resultados.

Métricas: conectan, de forma cuantificable, los datos técnicos (CVE, SSVC, KEV, incidentes, SLA) con los objetivos de seguridad nacional y cumplimiento NIS2. [web:6][web:19][web:22][web:25][web:33][web:39]

Las secciones siguientes (ver archivo “Matriz de Evaluación PRAGMATIC Completa”) califican cada métrica bajo los criterios PRAGMATIC para priorizar las más útiles y realistas.